



CYBERSICUREZZA AZIENDALE

GUIDA PER I DIPENDENTI



AGENZIA PER
LA CYBERSICUREZZA
NAZIONALE

Le iniziative di promozione della cybersicurezza aziendale sono fondamentali per accelerare la presa di coscienza del ruolo chiave che la cybersicurezza riveste nella transizione digitale.

Molte realtà aziendali non hanno ancora intrapreso un percorso adeguato per proteggere i propri processi, oppure hanno adottato soluzioni solo parziali. Questa situazione è spesso causata dalla mancanza di una pianificazione strutturata e, soprattutto, alla scarsa priorità assegnata alle misure volte a potenziare la capacità di prevenzione, monitoraggio e contrasto delle minacce informatiche, in relazione al livello di esposizione ai rischi.

4,5 milioni
di PMI
sempre più a rischio di
attacchi
informatici

Le piccole e medie imprese (PMI) Italiane (circa 4,5 milioni di imprese¹) rappresentano un asse portante del motore economico del Paese. Molte di esse operano nelle filiere di operatori pubblici e privati che gestiscono infrastrutture critiche nazionali. Le analisi condotte dal Computer Security Incident Response Team (CSIRT Italia) dell'Agenzia per la Cybersicurezza Nazionale, insieme alle statistiche ufficiali e ai principali report di settore, evidenziano come gli **attacchi informatici ai danni delle PMI siano in**

L'uso preponderante di malware, ransomware e phishing, evidenzia come il cyber crimine sfrutti sempre più l'impreparazione in termini di cybersicurezza e l'errore umano a proprio vantaggio.

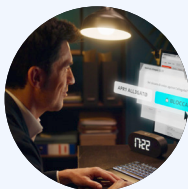
¹ ISTAT, Registro statistico delle imprese attive (2023), includendo le imprese con numero di addetti minore di 10 (microimprese) e le imprese con numero di addetti tra 10 e 250.

² Eurostat, Security incidents and consequences by size class of enterprise (2024). Nel 2024 il 15,8% delle imprese con numero di addetti tra 10 e 250 ha riportato di aver avuto nel corso dell'anno precedente almeno un problema di sicurezza ICT che ha determinato un impatto tra indisponibilità di servizi ICT, distruzione o corruzione dei dati, divulgazione di dati riservati (contro il 9,9% nel 2019).

Con l'introduzione di normative più recenti, come la Direttiva NIS2, **è essenziale che le PMI aumentino il loro presidio di sicurezza riducendo la superficie esposta alle minacce informatiche e mitigando gli impatti di eventuali attacchi cyber**. Oltre alle misure tecniche, assumono un'importanza cruciale anche quelle organizzative e procedurali. In questo contesto, risultano centrali **la consapevolezza e la formazione in materia di cybersicurezza**, così come la **pianificazione dei processi per la gestione delle crisi e il controllo della catena di approvvigionamento** (la cosiddetta supply chain).

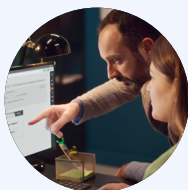


È fondamentale diffondere una buona cultura della cybersicurezza a tutti i livelli dell'organizzazione:



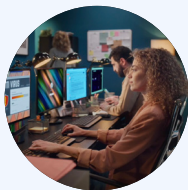
DIRIGENTI D'AZIENDA

affinché pianifichino, attraverso l'allocazione di **budget e risorse**, l'acquisto di servizi e infrastrutture, e promuovano corsi di formazione o altre **iniziative di sensibilizzazione** volte al potenziamento di una cultura della cybersicurezza.



PROFESSIONISTI IT

affinché proteggano l'organizzazione dai rischi cyber, individuando, supportati dalla dirigenza, adeguate misure e iniziative di sicurezza atte a prevenire o ridurre le conseguenze di eventuali incidenti cyber, in conformità con le normative vigenti.



DIPENDENTI

affinché collaborino per il mantenimento della cybersicurezza aziendale, partecipando a iniziative di formazione e adottando le precauzioni suggerite dalla propria organizzazione al fine duplice di tutelarsi dalle minacce e contribuire in modo positivo al loro riconoscimento e alla mitigazione dei relativi impatti sull'organizzazione.

Nei paragrafi seguenti sono riportate **le principali indicazioni rivolte ai dipendenti con l'obiettivo di rafforzare** l'adozione delle misure di sicurezza per **protegersi dai principali tipi di attacco** (tra cui, ad esempio, phishing, ransomware e malware) in diverse situazioni operative, quali ad esempio lo smart working o le trasferte professionali. **La guida supporta i dipendenti delle PMI nell'acquisizione di una maggiore consapevolezza sull'importanza del rispetto di buone pratiche di cybersicurezza nelle attività lavorative e nei processi operativi**, al fine di sostenere l'innalzamento del livello di cybersicurezza complessivo dell'organizzazione. Per ciascun argomento si riportano:



Una **sintesi** (o elenco di “**azioni chiave**”) che raccoglie i principali messaggi e comportamenti raccomandati in materia di cybersicurezza.



Contenuti in **dettaglio**: indicazioni operative strutturate sotto forma di linee guida.

N.B. Nel contesto di questo documento, per **informazioni riservate** si intendono **tutte quelle informazioni** trattate all'interno dei processi aziendali per cui è determinante garantire confidenzialità, e **la cui diffusione non autorizzata, alterazione, perdita può comportare un danno significativo per l'azienda e/o per i clienti e/o per altre parti coinvolte**. Queste informazioni possono includere dati personali, informazioni finanziarie, strategie aziendali, proprietà intellettuale, brevetti e altre informazioni. Tra le informazioni riservate sono incluse anche le cosiddette informazioni critiche ovvero le informazioni considerate particolarmente rilevanti per l'operatività e lo svolgimento del business dell'organizzazione.

AZIONI NECESSARIE PER UN'IMPRESA PIÙ SICURA

1

Partecipa in maniera attiva alle iniziative di comunicazione e/o di awareness proposte dalla tua organizzazione.

AZIONI CHIAVE

1. La cybersicurezza è una responsabilità condivisa. Ricorda che anche tu, come ogni membro dell'organizzazione hai un ruolo nel garantire un ambiente sicuro.

2. Informati e verifica di essere a conoscenza di tutte le indicazioni e linee guida per la sicurezza informatica della tua organizzazione, a partire dall'individuazione delle strutture o dei referenti responsabili. Qualora queste non fossero presenti, assumi un ruolo attivo per sollecitarne la predisposizione.

3. Comprendi il valore delle tue azioni quotidiane e il loro impatto sulla cybersicurezza dell'organizzazione.

4. Partecipa attivamente alle iniziative di awareness e alle simulazioni promosse dalla tua organizzazione.

5. Accogli eventuali suggerimenti provenienti dalla tua organizzazione finalizzati a promuovere la partecipazione ad azioni volte al miglioramento continuo, con l'obiettivo di favorire il mantenimento di un adeguato livello di cybersicurezza.

6. Accertati di aver compreso appieno il tuo ruolo, e le responsabilità connesse, in linea con le direttive dell'organizzazione, per contribuire attivamente alla protezione del patrimonio informativo aziendale.

CONTENUTI IN DETTAGLIO

I dipendenti svolgono un ruolo fondamentale nella protezione dei dati e dei sistemi dell'organizzazione e nel corretto utilizzo dei beni aziendali secondo le indicazioni (es. politiche, linee guida, procedure) definite dall'organizzazione. Per questo, è fondamentale che ogni dipendente abbia una solida cultura della cybersicurezza e sia a conoscenza dei rischi e delle minacce cui può andare incontro mentre utilizza gli strumenti di lavoro.

È quindi necessario che ogni dipendente:

- **Partecipi attivamente ai corsi di formazione**

e alle iniziative di sensibilizzazione che vengono promosse dall'organizzazione in materia di cybersicurezza.

- **Partecipi attivamente alle attività di testing e valutazione della comprensione delle tematiche di cybersicurezza**

successive alle iniziative di formazione e sensibilizzazione promosse dall'organizzazione.

- **Partecipi attivamente alle simulazioni periodiche**

eventualmente promosse dall'organizzazione (esercitazioni di risposta agli incidenti informatici).

- **Si informi proattivamente e adotti concretamente le indicazioni fornite dall'organizzazione in ambito cybersecurity**

(es. politiche, linee guida, procedure).

È importante, infatti, che ciascun dipendente abbia ben chiare le proprie responsabilità nella protezione dei dati e dei dispositivi aziendali e nonchè il ruolo fondamentale che può avere nel segnalare tempestivamente eventuali anomalie o criticità.

Qualora non fossero fornite specifiche indicazioni sulla cybersicurezza, si raccomanda di contattare i referenti tecnici di riferimento e di assumere un ruolo attivo per **richiedere un supporto e sollecitare l'elaborazione di linee guida o istruzioni operative**.

Quali sono le conseguenze di una mancata partecipazione attiva alle iniziative di formazione e/o di awareness proposte dall'organizzazione?

La mancata partecipazione alle iniziative di formazione e/o di awareness promosse dall'organizzazione **aumenta notevolmente la possibilità di restare vittima di attacchi informatici**, con conseguenti perdite significative causate dal furto di dati per l'accesso non autorizzato ad informazioni riservate aziendali e dei singoli individui, nonché significativi danni finanziari e reputazionali per l'intera organizzazione.

La scarsa consapevolezza delle responsabilità legate alla protezione dei dati e dei dispositivi aziendali può comportare, in caso di incidente informatico, una risposta tardiva e disorganizzata da parte dell'organizzazione. Questo ritardo favorisce l'azione dei cybercriminali, facilitando la diffusione di malware e virus, con conseguente compromissione dei dati.

Prestare poca attenzione alle indicazioni di sicurezza fornite dall'organizzazione, **aumenta la possibilità di cedere**, inconsapevolmente, **credenziali di accesso o altre informazioni riservate ai cybercriminali** che possono generare accessi non autorizzati a account online e sistemi informatici, furti di identità, frodi finanziarie, manipolazioni o altre attività dannose per l'organizzazione.

2

Presta particolare attenzione alle tecniche di social engineering e, in particolare, al phishing

AZIONI CHIAVE

1. Diffida di telefonate, sms e/o e-mail

in cui vengono richieste informazioni sui dipendenti o altre informazioni interne.

2. Non fornire informazioni personali

e riservate sulla tua organizzazione, a meno che non sei certo dell'identità della controparte che le richiede.

3. Se ricevi messaggi sospetti presta attenzione a eventuali errori di ortografia o di grammatica.

4. In caso di link o allegati sospetti, verificane l'attendibilità posizionando il cursore sul link senza cliccare per controllare preliminarmente la pagina web a cui si viene reindirizzati.

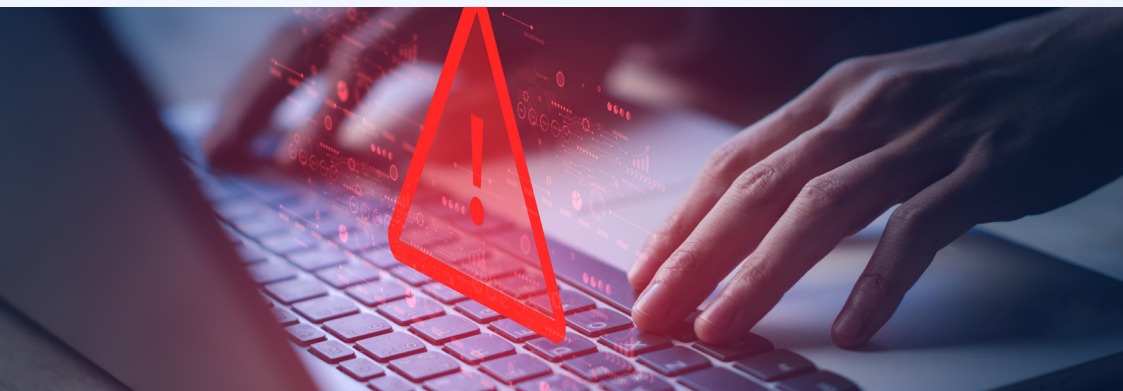
5. Se ricevi un'e-mail sospetta, segnalala tempestivamente all'organizzazione, con l'obiettivo di collaborare alla protezione dei dati e delle risorse aziendali da potenziali violazioni.

CONTENUTI DI DETTAGLIO

Nel panorama delle minacce di tipo social engineering, i cybercriminali si avvalgono di metodi sempre più sofisticati per **trarre in inganno le vittime e indurle a compiere azioni che potrebbero compromettere la cybersicurezza personale e dell'organizzazione.**

Cos'è il social engineering?

Il social engineering è una tecnica di attacco che sfrutta l'errore o la debolezza umana anziché le vulnerabilità tecniche dei sistemi informatici e di rete, **per indurre le persone a compiere inconsapevolmente azioni dannose.** Tra queste, ad esempio, il download di malware, la condivisione di informazioni personali o riservate dell'organizzazione. Gli attacchi di questo tipo possono avvenire attraverso vari canali, si pensi, ad esempio, al caso di telefonate in cui l'aggressore si finge un dipendente o un superiore, oppure alla creazione di identità false, sfruttando relazioni personali o professionali, per ottenere la fiducia della vittima. Pertanto, la consapevolezza degli utenti e un'adeguata formazione a supporto assumono un'importanza fondamentale nella prevenzione di tali attacchi cyber. Fra tutte le tecniche di social engineering, la più diffusa è sicuramente il phishing.



Cos'è il phishing?

Il phishing è un attacco informatico avente, generalmente, **l'obiettivo di carpire informazioni riservate** (ad es. user ID, password, numeri di carte di credito, PIN) **tramite l'invio di e-mail malevole ad un gran numero di indirizzi. Le e-mail sono consegnate per convincere i destinatari ad aprire un allegato o a collegarsi a falsi siti web.** L'attaccante in questi casi utilizza i dati

carpiti per acquistare beni, trasferire somme di denaro o anche solo come “ponte” per ulteriori attacchi. In alcuni casi, l'attaccante utilizza una tecnica nota come **spear phishing**, che prende di mira specifiche persone o gruppi ristretti, inviando loro messaggi costruiti ad hoc, utilizzando loghi e altri riferimenti grafici mirati a rafforzare la credibilità e l'attendibilità della richiesta.

Le frodi che sfruttano l'Intelligenza Artificiale (IA)

Nei prossimi anni, ci si aspetta un aumento significativo delle campagne di phishing, e in particolare di spear phishing, favorito dalla diffusione dell'Intelligenza Artificiale (IA) generativa. L'IA generativa consente di creare contenuti falsi estremamente realistici — come immagini, video e registrazioni vocali — riproducendo in modo credibile tratti anatomici, espressioni facciali e movimenti, al fine di ingannare le vittime.

Esempi comuni di phishing

Gli attacchi di phishing non si limitano all'uso dell'e-mail come canale di diffusione, ma si avvalgono anche di messaggi di testo o SMS (Smishing) e chiamate vocali (Vishing); l'obiettivo rimane però invariato: trarre in inganno la vittima ed indurla a commettere l'errore desiderato.

Tipologie di attacco	Strumenti utilizzati per l'attacco	Target
Phishing	E-mail	Dipendenti
Smishing	Messaggi di testo o SMS	Dipendenti
Vishing	Chiamate vocali	Dipendenti
Whaling	E-mail	Dirigenti (es. CEO e CFO)

NEL DETTAGLIO

▪ Phishing, un attacco che utilizza le e-mail:

la tecnica adottata dal phishing consiste nell'inviare un'email che contiene un link o un allegato dannoso, progettato per indurre l'utente a fornire informazioni personali o a scaricare malware.

▪ Smishing, un attacco che utilizza i messaggi di testo o SMS;

la tecnica adottata consiste nell'inviare a un telefono cellulare o a uno smartphone tramite SMS un messaggio che contiene link o un numero di telefono da richiamare.

▪ Vishing, un attacco che utilizza una chiamata vocale per estorcere informazioni.

▪ Whaling, un attacco che prende tipicamente di mira la dirigenza. Un esempio tipico consiste nell'invio di un'e-mail apparentemente legittima che segnala allarmi gravi, come imminenti azioni legali contro l'azienda.

Il messaggio invita il destinatario a cliccare su un link per ottenere maggiori dettagli.

Il collegamento rimanda a una pagina finta che simula un portale ufficiale e richiede l'inserimento di informazioni riservate, come codici fiscali, credenziali di accesso o dati bancari aziendali, che verranno poi sfruttati dai cybercriminali per compiere frodi o furti d'identità.

Cosa accomuna tutte queste tipologie di attacco?

Nonostante le diverse modalità, ci sono dei **segnali** comuni a tutti gli attacchi di phishing, che permettono di riconoscere “messaggi” sospetti:



Mittenti non chiaramente identificabili o sconosciuti
che propongono operazioni inusuali.



Link presenti nel messaggio, che possono scaricare malware sul PC o sul dispositivo mobile (es. smartphone, tablet). È quindi opportuno essere certi dell'affidabilità della pagina web a cui si viene reindirizzati.



Allegati contenuti in messaggi di cui non si conosce la provenienza o dei quali non è chiaro l'oggetto, e che se aperti possono scaricare malware sul PC o sul dispositivo mobile.



Uso di un **tono allarmistico e senso di urgenza**, (es. blocco account, mancati pagamenti, mancati rinnovi contrattuali) per catturare l'attenzione e spingere ad agire rapidamente prima che si abbia il tempo di pensare alla richiesta in modo più critico.



Errori di ortografia e/o di grammatica.

Come proteggersi dagli attacchi informatici

▪ **Diffida di telefonate, sms e/o e-mail** che chiedono informazioni sui dipendenti o altre informazioni interne. Se un individuo sconosciuto dichiara di provenire da un'organizzazione legittima, è importante verificare la sua identità direttamente con l'azienda.

▪ **Non fornire informazioni personali o aziendali**, a meno che non sia stata verificata l'identità e l'autorizzazione del destinatario a riceverle.

▪ **Non inviare informazioni riservate via Internet prima di aver verificato la sicurezza di un sito web.** Le URL che iniziano con “https” (piuttosto che “http”) indicano che la connessione al sito web offre garanzie di sicurezza; o cerca l'icona di un lucchetto chiuso, segno che le informazioni sono trasmesse su canale cifrato.

▪ **Se ricevi una chiamata**, una e-mail o un altro tipo di richiesta di contatto e non sei certo della legittimità della richiesta, **verifica l'autenticità chiamando direttamente l'azienda coinvolta**. Evita di utilizzare i recapiti presenti nel messaggio, fai invece riferimento a canali di contatto verificati.

▪ **Fai attenzione ai deepfake, ovvero video, audio e foto di persone che sembrano autentiche, ma che in realtà sono create utilizzando l'Intelligenza Artificiale al fine di ingannare**. In caso di dubbi, verifica l'origine e l'affidabilità della fonte anche tramite controlli incrociati tra quelle più autorevoli.

Quali conseguenze comporta un basso livello di precauzione nei confronti del phishing e del social engineering?

La condivisione di informazioni personali o dell'organizzazione a persone non autorizzate o su siti non sicuri può comportare **furti di identità**, captazione **di informazioni aziendali** (es. strategie aziendali, dati finanziari o proprietà intellettuale) **o di dati personali di clienti**.

Se non si presta adeguata attenzione a link e ad allegati sospetti, **si rischia di distribuire inconsapevolmente virus e malware** all'interno dell'organizzazione con conseguente possibilità di furto, manipolazione e compromissione di dati o controllo remoto dei dispositivi.

Se non si è attenti alla ricezione di messaggi sospetti, (e-mail, sms e chiamate) **si rischia di essere soggetti a furti di credenziali**, permettendo accessi non autorizzati ad account e sistemi aziendali, con conseguenti furti di dati, frodi o transazioni non autorizzate.

3

Genera e gestisci le tue credenziali in modo sicuro, evitando di riutilizzarle

AZIONI CHIAVE

1. Utilizza sempre password robuste, in linea con le indicazioni della tua organizzazione e con le buone pratiche di sicurezza riconosciute.

2. Cambia la tua password al primo accesso e ogni volta che sospetti possa essere stata compromessa o conosciuta da terzi.

3. Scegli attentamente ed utilizza uno strumento per la conservazione sicura delle password (es. password manager) in linea con le indicazioni della tua organizzazione.

4. Non utilizzare nelle password informazioni personali che possono essere facilmente reperite online o sui social (es. data di nascita o nome dei figli).

5. Non riutilizzare la stessa password per più account, soprattutto fra account aziendali e personali, e non condividerla con nessuno.

6. Attiva, dove possibile, l'MFA (Autenticazione a più fattori) e per i servizi aziendali adottala in linea con le indicazioni della tua organizzazione.

Proteggere le credenziali è fondamentale per garantire la cybersicurezza personale e dell'organizzazione.



CONTENUTI DI DETTAGLIO

Tecniche di attacco come quelle **a forza bruta**, possono individuare la password d'accesso **sfruttando un algoritmo che elabora le diverse combinazioni fino ad individuare quella corretta**. Per questo è importante definire una password robusta conforme alle indicazioni e alla password policy dell'organizzazione o comunque alle pratiche di sicurezza riconosciute³. Se non si dispone di indicazioni o password policy specifiche da parte dell'organizzazione, si consiglia di contattare i responsabili che gestiscono

³ Rif. Cybersecurity Basics | NIST, Identity and Access Management Roadmap | NIST.

le dotazioni informatiche e chiedere loro supporto sulle linee guida da seguire.

Riassumendo, per una password ancora più robusta e sicura si raccomanda di:

- **Non utilizzare per i sistemi aziendali le stesse password usate per gli account personali.**
- **Non condividere la password con i colleghi,** in quanto è un'informazione di accesso personale che deve essere utilizzata esclusivamente dal titolare dell'account.
- **Cambia la tua password al primo accesso,** qualora non sia stata direttamente scelta, ma comunicata da altri soggetti o dal personale ICT dell'organizzazione.
- **Se hai il sospetto che la tua password possa essere nota ad altri,** segnala tempestivamente l'evento all'organizzazione come incidente di sicurezza.
- **Utilizza un password manager** in linea con le indicazioni e la password policy dell'organizzazione: questo strumento consente di conservare in modo sicuro le credenziali, permettendo di utilizzare password diverse tra loro, robuste e difficili da indovinare, ricordandone una sola per accedere a tutte le altre. Considerata la diffusione di software malevoli che si spacciano per password manager, è fondamentale selezionare e scaricare l'applicazione esclusivamente da fonti attendibili, seguendo le indicazioni fornite dall'organizzazione⁴.

MFA

Per garantire una maggiore sicurezza degli account, è necessario aggiungere altri livelli di autenticazione oltre alla password, adottando cioè **l'autenticazione a più fattori o Multi Factor Authentication (MFA)**. L'MFA è un meccanismo che **verifica l'identità di un utente richiedendo l'inserimento di dati aggiuntivi rispetto al solo nome utente password**. Forme comuni di MFA sono messaggi di testo SMS inviati ad un telefono cellulare o a uno smartphone, codici a 6 cifre generati da app, notifiche push inviate al dispositivo e chiavi di sicurezza fisiche. L'MFA richiede all'utente di fornire due o più dei seguenti elementi:

- **Qualcosa che l'utente possiede:** es. un token fisico o un'applicazione per l'autenticazione.
- **Qualcosa che l'utente conosce:** es. password, passphrase o PIN.
- **Qualcosa che l'utente "è":** un dato biometrico come l'impronta digitale, il riconoscimento facciale o l'impronta retinica.

⁴ Anche in tal caso, qualora non si disponessero di indicazioni o password policy specifiche da parte dell'organizzazione, si consiglia di contattare i responsabili che gestiscono le dotazioni e chiedere loro supporto sulle linee guida da seguire.

In merito all'abilitazione dell'MFA sui servizi e sui software aziendali, si raccomanda di seguire puntualmente le indicazioni (es. politiche, linee guida, procedure) fornite dall'organizzazione. Inoltre, al di fuori del contesto lavorativo, si suggerisce di attivare la funzionalità di MFA ovunque possibile (es. app di messaggistica, piattaforme social, e-mail privata, online banking) in quanto è tra le azioni più efficaci per proteggere la sicurezza dei dati e dei sistemi. **Gli utenti che abilitano l'MFA hanno minori probabilità di compromissione dei propri account.** Perché anche se un fattore (come la password) viene compromesso, gli utenti non autorizzati non saranno in grado di soddisfare il secondo requisito di autenticazione, impedendo loro di accedere all'account.

Cosa comporta una protezione insufficiente delle credenziali e il mancato utilizzo dell'MFA?

L'utilizzo della stessa password per più di un account **agevola i cybercriminali**. Spesso, infatti, le password compromesse vengono riutilizzate per accedere ad altri servizi e permettere il furto di informazioni riservate, aziendali e di clienti.

Appuntare la password su post-it o bigliettini potrebbe comportare, non solo il furto di credenziali da parte di utenti malintenzionati, ma **permette anche a colleghi non autorizzati di accedere a servizi e informazioni riservate**.

L'utilizzo di password contenenti informazioni personali, presenti su piattaforme online o social network, come ad esempio la data di compleanno, **agevola utenti malintenzionati a reperire le credenziali più facilmente** ed effettuare accessi non autorizzati ad account e sistemi informatici.

Non usare l'autenticazione a più fattori in quanto aumenta il rischio di violazioni, perché se un fattore, come la password, viene compromesso, gli utenti non autorizzati saranno in grado di accedere molto facilmente all'account, dal momento che non verrà richiesto loro nessun ulteriore requisito di autenticazione che possa impedirgli di violare le credenziali.

4

Fai regolarmente il backup dei dati aziendali su supporti autorizzati e, se previsto, sulla piattaforma cloud della tua organizzazione

AZIONI CHIAVE

1. Archivia regolarmente i dati e le informazioni dell'organizzazione solo su dispositivi autorizzati e quando possibile attiva il backup automatico.

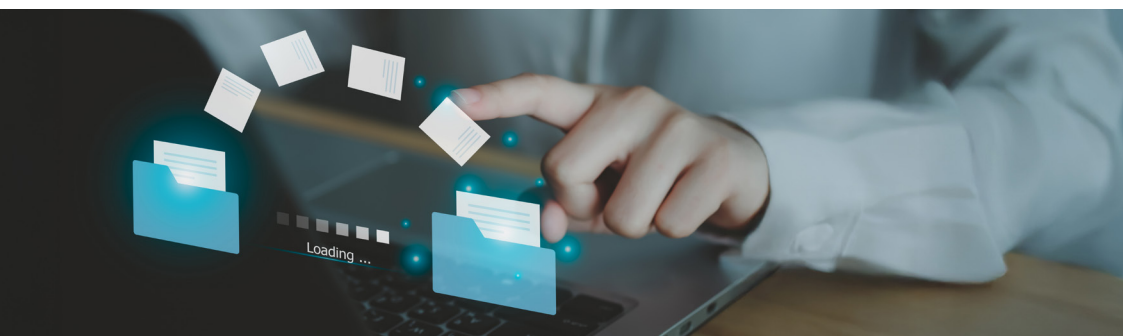
2. Per il backup prediligi sempre la piattaforma cloud della tua organizzazione, così da archiviare i dati in modo sicuro.

Su richiesta dell'organizzazione, i dati in cloud possono essere protetti attraverso la crittografia e possono essere raggiungibili sempre e ovunque grazie all'utilizzo di

infrastrutture ridondanti e resilienti che garantiscono la disponibilità dei dati con le indicazioni della tua organizzazione.

3. Favorisci, dove possibile, un approccio multiplo, che preveda sia backup locali che in cloud, agevolando così un livello maggiore di protezione e resilienza contro la perdita di dati.

4. Una volta terminato il backup su dispositivo autorizzato rimuovilo e conservalo in un luogo sicuro.



CONTENUTI DI DETTAGLIO

Il backup consiste nella duplicazione di un file o di un insieme di dati in un luogo separato con lo scopo di proteggerli. È un'operazione fondamentale per garantire la cybersicurezza, perché **protegge i dati da perdite, danni accidentali o volontari, e consente di recuperarli tempestivamente in caso di necessità.** Infatti, in caso di perdita o compromissione degli

stessi, le copie di backup ne consentono un ripristino rapido e affidabile, riducendo al minimo il tempo di inattività e il potenziale impatto sulle operazioni all'interno dell'organizzazione.

Effettuare regolarmente il backup dei dati è vivamente consigliato a qualsiasi organizzazione, per non comprometterne l'integrità e la disponibilità nel lungo termine, aspetti fondamentali per il business in caso di incidenti o di attacchi informatici. È sempre necessario rimuovere il supporto esterno (autorizzato dalla propria organizzazione) una volta terminato il backup.

Nell'esecuzione del backup, è fondamentale, tenere presente i seguenti aspetti:

1. Non salvare o archiviare dati e informazioni dell'organizzazione su dispositivi e supporti non autorizzati dall'organizzazione stessa

(es. dispositivi di archiviazione usb o hard disk esterni non cifrati, siti cloud usati per svago o attività personali).

2. Assicurate che il backup sia impostato in maniera automatica o venga effettuato

regolarmente e/o secondo le regole fornite dall'organizzazione.

3. Usa dispositivi criptati, soprattutto se contengono dati riservati o critici per l'organizzazione o se sono soggetti a spostamenti tra diversi luoghi, in modo da renderli inaccessibili a persone non autorizzate ed innocui in caso di furto.

Cosa si rischia se non si effettua regolarmente e con le giuste regole il backup?

La mancata esecuzione dei backup e/o una non adeguata impostazione degli stessi, **espone l'organizzazione al rischio di indisponibilità di dati** che può compromettere la continuità del business, costituendo incidenti di sicurezza che possono elevarsi a situazioni di crisi.

La mancata esecuzione dei backup e/o una non adeguata impostazione degli stessi **comporta, in caso di furto o smarrimento dei dispositivi aziendali, la perdita di dati** e di informazioni necessarie per l'organizzazione.

La mancata cifratura del backup comporta il rischio che persone non autorizzate accedano a informazioni riservate, aziendali o dei clienti, come strategie aziendali, dati finanziari o di proprietà intellettuale.

5

Seleziona sempre con chi condividere dati e stai attento a condivisioni involontarie (social media: foto con dati riservati; e-mail: destinatari o allegati errati)

AZIONI CHIAVE

1. Non divulgare informazioni riservate relative al tuo lavoro.

2. Utilizza solo sistemi di messaggistica e strumenti di file sharing approvati dalla tua organizzazione.

3. Condividi informazioni riservate per il tuo lavoro solo se strettamente necessario e solo a persone autorizzate.

4. In caso di invio via e-mail di documenti contenenti informazioni riservate, utilizza un processo che preveda una cifratura dei dati.

5. Usa consapevolmente i social e tutti i programmi/servizi disponibili sul web, facendo attenzione a non condividere informazioni relative all'ambiente di lavoro, progetti e attività che stai svolgendo.

6. Evita di inserire informazioni sensibili o documenti riservati in programmi/servizi che editano o generano contenuti (es. sistemi di IA, traduttori linguistici, editor PDF) durante lo svolgimento del tuo lavoro.

CONTENUTI DI DETTAGLIO

A fronte della quantità di informazioni che vengono gestite dalle organizzazioni, **garantire la sicurezza e la protezione dei dati è diventato un punto chiave nella società moderna.**

Nel mondo digitale sempre più interconnesso, la condivisione di dati è una pratica comune; tuttavia, è fondamentale prestare attenzione nella scelta delle persone con cui condividere le informazioni, soprattutto quelle relative all'ambito lavorativo, **al fine di proteggere la sicurezza dei dati aziendali e non compromettere la propria organizzazione.** A tal proposito, è fondamentale evitare di divulgare informazioni riservate per il business e l'organizzazione. A tutela dei dati e della continuità operativa, è importante attenersi a comportamenti consapevoli e tenere in considerazione alcuni aspetti chiave per la loro corretta gestione e protezione.

IN DETTAGLIO

- **Evita di divulgare informazioni riservate dell'organizzazione a colleghi di altre aree o terze parti non autorizzate** ad entrare in possesso di tali dati.

- **Non lasciare incustoditi documenti riservati dell'organizzazione in luoghi accessibili** (es. scrivania, aree comuni).

- **Non condividere file/cartelle/documenti se non strettamente necessario;** non condividere mai l'intero disco o la documentazione di un intero progetto, ma solo i singoli elementi, per un periodo di tempo limitato.

- **Utilizza sistemi di messaggistica e strumenti di file sharing approvati dall'organizzazione.**



È necessario evitare di:

Pubblicare su social informazioni rilevanti per l'organizzazione

o che possano ledere l'immagine o la reputazione della stessa.

Si raccomanda di:

a. Non pubblicare foto relative agli ambienti di lavoro o informazioni di lavoro, perché ciò potrebbe fornire informazioni utili ad eventuali attaccanti.

b. Non pubblicare sui social media informazioni legate all'organizzazione per cui non sia stata preventivamente autorizzata la divulgazione.

c. Esprimere sui social media eventuali opinioni riguardanti l'attività lavorativa come punti di vista personali, e non rispecchianti la posizione dell'organizzazione.

Condividere e/o "caricare" informazioni aziendali riservate su programmi e/o servizi che aiutino a editare o generare del contenuto;

ad esempio, si raccomanda di:

a. Non usare strumenti di intelligenza artificiale generativa di terze parti per produrre una relazione o sulle attività alle quali si partecipa.

b. Non usare traduttori automatici per tradurre documenti lavorativi con dati riservati dell'organizzazione o dei suoi clienti.

c. Non caricare documenti su PDF Editor online per scansionare il testo o editare file PDF; per farlo utilizza programmi autorizzati dall'organizzazione.

Seguire queste indicazioni è importante per **tenere al sicuro i dati dell'organizzazione ed evitare rischi reputazionali, legali ed economici**, che potrebbero compromettere la fiducia e la credibilità dell'azienda agli occhi di clienti, fornitori e investitori.

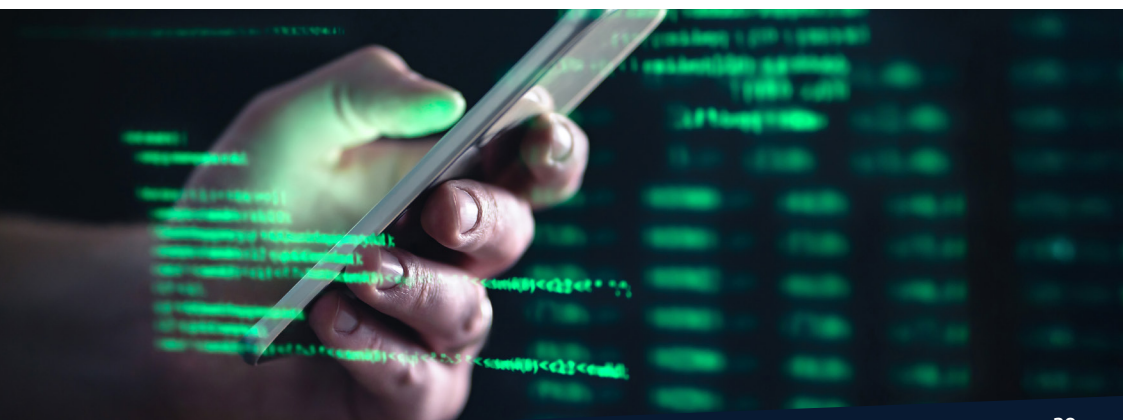
Quali sono le conseguenze di condivisioni inopportune o involontarie dei dati?

La mancanza di attenzione nella gestione di informazioni riservate sull'organizzazione e/o sui clienti, come ad esempio lasciare il documento incustodito sulla scrivania o inviarlo ad un destinatario non corretto e non autorizzato, **genera una fuoriuscita di dati che aumenta il rischio di frodi o furto di proprietà intellettuale** da parte di soggetti disonesti.

La mancata cifratura di documenti inviati in chiaro via e-mail, o l'inserimento di dati aziendali su servizi online non autorizzati, **consente a personale non autorizzato di venire a contatto con informazioni riservate**, generando anche in questo caso una fuoriuscita di dati.

La condivisione sui social media di informazioni aziendali relative ad ambienti di lavoro (e/o riservati), informazioni sui progetti o altre informazioni connesse alla sfera lavorativa, **aiutano i cybercriminali ad effettuare attacchi mirati come il phishing** e altre tecniche di social engineering.

La condivisione sui social media di opinioni riguardanti l'attività lavorativa, non identificabili come punti di vista personali, e di informazioni strategiche per cui non sia stata preventivamente autorizzata la divulgazione, **comporta seri danni reputazionali con conseguenti ripercussioni economiche** derivanti dalla perdita di fiducia e di credibilità nei confronti dell'organizzazione.



6

Aggiorna regolarmente i software e l'antivirus:
è un tassello fondamentale della cybersicurezza aziendale.

AZIONI CHIAVE

1. Aggiorna regolarmente il software e tutti i dispositivi (es. PC, smartphone, tablet) per mantenere alto il loro livello di sicurezza.

2. Attiva l'aggiornamento automatico se possibile.

3. Assicurati di scaricare gli aggiornamenti software solo dai siti web di fornitori affidabili.

4. Non effettuare l'aggiornamento dei tuoi dispositivi se non sei connesso

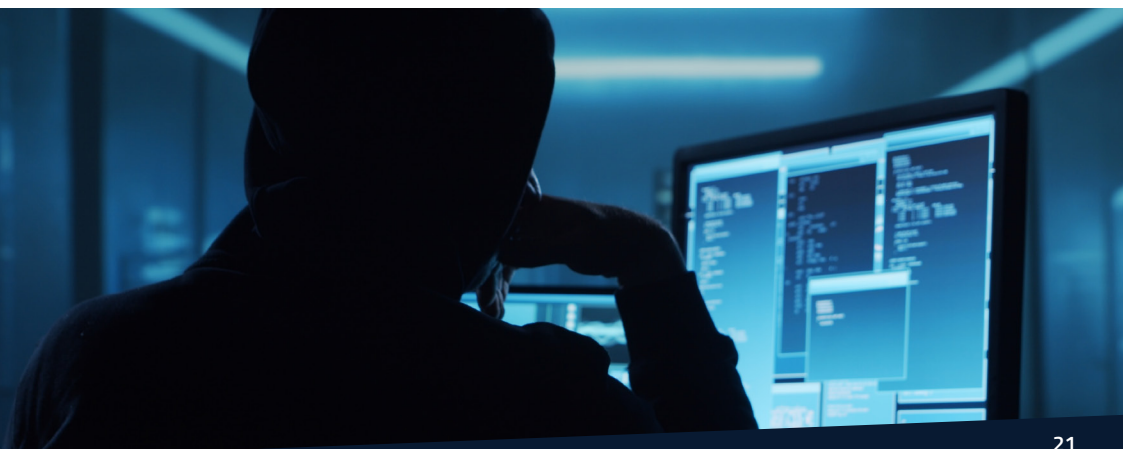
ad una rete affidabile.

5. Verifica che l'antivirus sia installato ed aggiornato sui tuoi dispositivi per tutelare le informazioni dell'organizzazione.

6. Qualora avessi problemi di aggiornamento software o antivirus contatta, quanto prima, i responsabili che gestiscono la sicurezza dei tuoi dispositivi.

CONTENUTI DI DETTAGLIO

Curare regolarmente l'aggiornamento del software e dell'antivirus è fondamentale per proteggere in maniera proattiva gli asset e i dati dell'organizzazione.



Aggiornamento del software

L'**aggiornamento del software**, e dei dispositivi in generale, non consente solo di accedere a nuove funzionalità o interfacce, **ma permette di mantenere un alto livello di sicurezza all'interno dell'organizzazione.**

L'aggiornamento consente di proteggere PC, smartphone o altri dispositivi digitali dai cybercriminali che, attraverso lo sfruttamento di vulnerabilità di sistema, potrebbero compromettere la sicurezza dell'organizzazione.

Antivirus

L'**antivirus è un software che riconosce la presenza di virus informatici nei file e nelle memorie di massa e cerca di rimuoverli o di neutralizzarli, evitando l'installazione non autorizzata di software malevoli.** Gli aggiornamenti vengono distribuiti con una certa regolarità ai dipendenti dell'organizzazione, con l'obiettivo di assicurarsi che il software di protezione sia in grado di rilevare le ultime minacce mantenendo così un ambiente sicuro per i sistemi e i dati che vi risiedono. Pertanto, è fondamentale assicurarsi di **mantenere l'antivirus sempre aggiornato per affrontare le nuove varianti di malware e altre forme di software dannoso**, che vengono rilasciate ad intervalli frequenti dagli attori malevoli principalmente per eludere le difese esistenti, e sfruttare vulnerabilità nel software non aggiornato. Un PC che non dispone di una soluzione antivirus è vulnerabile, e quindi potenzialmente soggetto ad attacchi.

È fondamentale quindi:

- **assicurarsi che nei dispositivi aziendali siano installati software antivirus**, e che questi siano aggiornati;
- **assicurarsi che i software antivirus siano attivi** e le rispettive firme aggiornate;
- **non disabilitare o inibire il corretto funzionamento del software antivirus;**
- **segnalare immediatamente una qualsiasi anomalia sul software antivirus** ai responsabili che gestiscono la sicurezza dei tuoi dispositivi.

Cosa comporta un aggiornamento non adeguato dei software e delle soluzioni antivirus?

Il mancato o ritardato aggiornamento del software dei dispositivi espone l'organizzazione al rischio di subire attacchi cyber effettuati attraverso lo sfruttamento di vulnerabilità conosciute e il conseguente accesso di cybercriminali agli account e ai sistemi aziendali, favorendo violazioni e furti di dati.

Scaricare aggiornamenti di software da siti non affidabili o da e-mail di dubbia provenienza porta l'organizzazione ad **essere vittima di virus e malware** e minare così l'integrità ed il funzionamento dei sistemi, giungendo, in taluni casi, anche a bloccare l'operatività. **Non utilizzare un sistema antivirus aumenta esponenzialmente la probabilità di essere vulnerabili a virus e malware**, nonché la possibilità di diffonderli all'interno dell'organizzazione.

7

Su PC e smartphone aziendali installa esclusivamente applicazioni attendibili e strettamente necessarie per il tuo lavoro

AZIONI CHIAVE

1. Utilizza i dispositivi elettronici esclusivamente per attività connesse alle funzioni lavorative e non installare applicazioni ed app non strettamente necessarie per il tuo lavoro.

2. Ricordati che l'utilizzo della rete deve sempre essere indirizzato allo svolgimento di mansioni aziendali. Installa esclusivamente applicazioni attendibili ed autorizzate dalla

tua organizzazione; se non trovi l'applicazione che ti serve non scaricare software dal web, ma rivolgiti ai responsabili che gestiscono le tue dotazioni.

3. Concedi alle applicazioni e alle app solo le abilitazioni necessarie al loro utilizzo.

4. Non modificare le configurazioni di sistema standard impostate sui dispositivi aziendali.

CONTENUTI DI DETTAGLIO

Le applicazioni non attendibili possono rappresentare una potenziale minaccia per la cybersicurezza, introducendo malware o vulnerabilità nei sistemi. Mentre, **l'installazione di applicazioni non necessarie,** aggiornate con meno frequenza, **potrebbe essere, per le loro vulnerabilità note, un facile veicolo di attacco da parte dei cybercriminali,** aumentando considerevolmente la superficie di esposizione delle dotazioni aziendali al crimine organizzato.

Scegliere di installare esclusivamente applicazioni attendibili e strettamente necessarie per il proprio lavoro su PC e smartphone aziendali è fondamentale per garantire la sicurezza e la protezione dei dati dell'organizzazione.

Limitare le installazioni alle sole applicazioni attendibili ed indispensabili, infatti, **contribuisce a mantenere il proprio ambiente lavorativo più sicuro e protetto,** riducendo al minimo la potenziale minaccia di accessi non autorizzati o il rischio di compromissione delle attività lavorative.

Alcune buone pratiche da seguire per mantenere l'ambiente lavorativo sicuro e protetto.

- **Adotta esclusivamente i software autorizzati e consentiti dall'organizzazione;**

utilizza sempre il catalogo di app e l'elenco dei software approvati dall'organizzazione.

- **Non modificare le configurazioni di sistema standard impostate sui dispositivi aziendali.**

- **Non scaricare software dal web.**

Se non trovi l'applicazione necessaria, rivolgiti ai responsabili che gestiscono le dotazioni per farti aiutare ad installare e adottare esclusivamente programmi sicuri e attendibili.

- **Non installare o utilizzare software peer-to-peer su apparecchiature aziendali**

o su qualsiasi dispositivo connesso all'organizzazione o alle reti consentite per finalità lavorative.

- **Installa app solo da store autorizzati dall'organizzazione.** Quando scarichi un'app, verifica che gli sviluppatori siano affidabili e controlla sempre le valutazioni e i commenti. Prediligi le app con recensioni positive.

- **Non fornire mai ad applicazioni autorizzazioni non necessarie.**

Ad esempio, non cliccare su "Avanti" in una procedura guidata di installazione senza aver letto le condizioni e le istruzioni.

- **Leggi attentamente tutte le schermate delle procedure guidate di installazione:**

il software dannoso può celarsi all'interno di installazioni apparentemente sicure, mimetizzandosi tra programmi legittimi.

- **Utilizza solo plug-in strettamente necessari per lo svolgimento delle mansioni.**

- **Attieniti sempre alle linee guida fornite dall'organizzazione** sull'installazione e l'utilizzo sicuro di app e applicazioni e installa esclusivamente quelle strettamente necessarie per gli obiettivi aziendali.

- **In caso di riconsegna/sostituzione dei dispositivi, rimuovi tutte le informazioni personali e quelle riservate dell'organizzazione** dagli stessi e quando possibile ripristina il dispositivo alle impostazioni di fabbrica.



Cosa comporta l'installazione di applicazioni non attendibili e non strettamente necessarie per il tuo lavoro?

Se non si utilizzano software attendibili e approvati dall'organizzazione **si rischia di scaricare software malevoli e virus** e compromettere l'integrità e il funzionamento dei sistemi, eventualmente anche bloccando l'operatività dell'azienda.

Utilizzare applicazioni per svolgere attività non strettamente connesse con quelle lavorative **compromette fortemente la sicurezza dei sistemi dell'organizzazione**, aumentando considerevolmente la superficie di esposizione delle dotazioni aziendali agli attacchi cyber del crimine organizzato.



8

Lavora in modo sicuro ovunque ti trovi (a casa, in ufficio o in viaggio)

AZIONI CHIAVE

1. Prediligi sempre l'utilizzo di PC e dispositivi aziendali removibili e cifrati, piuttosto che quelli personali.

2. Se non sei in ufficio, presta attenzione al luogo in cui svolgi le attività lavorative, per evitare di diffondere inavvertitamente informazioni aziendali riservate.

3. Ovunque ti trovi non lasciare incustoditi laptop, smartphone o dispositivi di archiviazione aziendali.

4. Quando ti allontani dal PC (desktop o laptop) assicurati di bloccare lo schermo.

5. Collegati sempre ad Internet tramite reti sicure, evitando reti pubbliche aperte o reti non protette.

6. Non utilizzare stazioni di ricarica usb pubbliche quando sei in viaggio. Se non puoi farne a meno assicurati che il cavo USB sia abilitato solo al passaggio di corrente.

7. In caso di furto o smarrimento notifica l'accaduto quanto prima ai responsabili di pertinenza.

CONTENUTI DI DETTAGLIO

È fondamentale adottare, nei luoghi in cui si svolge il proprio lavoro, a casa, in ufficio o in viaggio, delle buone pratiche che prevengano i rischi relativi alla cybersicurezza aziendale.

Tali comportamenti sono di supporto alle misure di sicurezza definite dai professionisti ICT e, applicati dal personale, apportano un reale miglioramento nella prevenzione e gestione della sicurezza nei luoghi di lavoro.

L'attenzione e la protezione dei dispositivi aziendali connessi a reti esterne e da altri tipi di minacce logiche e fisiche, possono apparire azioni di poco conto, ma l'impatto che tale negligenza può generare nei confronti dell'organizzazione è esponenziale.

Nei punti a seguire si riportano alcune buone pratiche da tenere presenti per lavorare in modo sicuro.

Buone pratiche da adottare durante lo smartworking

▪ **Utilizza, se previsto dall'organizzazione, PC aziendali anziché personali.**

▪ Se disponibili, **assicurati di aver letto e ben compreso le indicazioni aziendali** (es. politiche, linee guida, procedure) **sul lavoro da remoto o "smart working"**, per accertarti che le pratiche di lavoro remoto siano conformi alle procedure aziendali e alle normative pertinenti.

▪ **Non utilizzare dispositivi, supporti e servizi che non siano espressamente autorizzati dall'organizzazione** (es. dispositivi di archiviazione usb, hard disk esterni, cloud pubblici non aziendali).

▪ **Svolgi le attività lavorative in un luogo sicuro evitando luoghi pubblici**, per scongiurare la condivisione involontaria d'informazioni aziendali riservate.

▪ **Utilizza preferibilmente una rete privata virtuale o Virtual Private Network (VPN) che garantisce la trasmissione dei dati su reti pubbliche in modo anonimo e sicuro** per

mantenere adeguati livelli di sicurezza e privacy, soprattutto se lavori da remoto rispetto alla sede principale dell'azienda e se hai la necessità di connetterti ai server interni aziendali per accedere ai dati in essi contenuti.

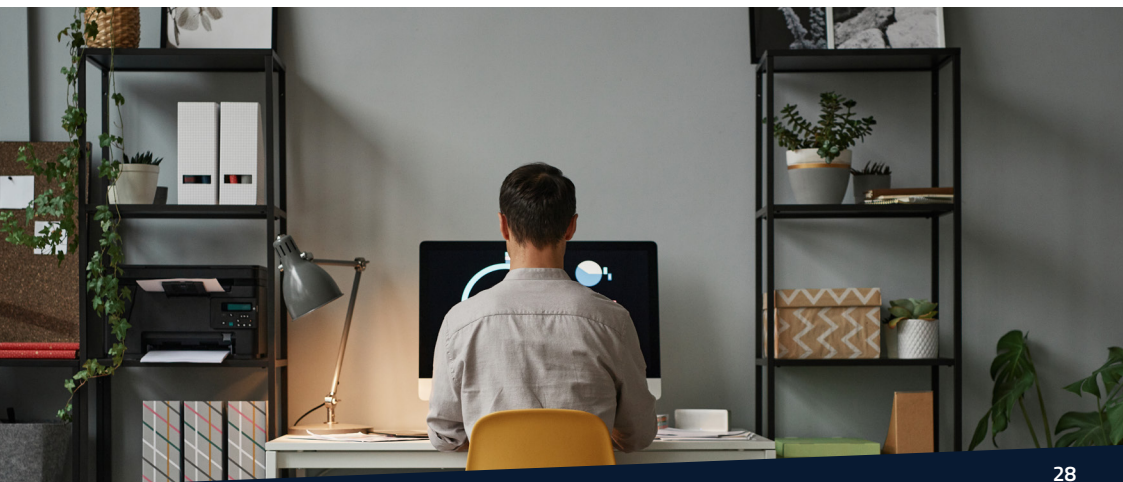
▪ **Collegati ad Internet tramite reti sicure**, evitando reti pubbliche aperte o reti non protette.

▪ **Usa, per quanto possibile, le risorse intranet aziendali per condividere i file di lavoro.**

▪ **Proteggi i dati a riposo**, ad esempio quelli memorizzati su disco locale del PC, tramite crittografia.

▪ **Disabilita i dispositivi rimovibili aziendali** (es. dispositivi di archiviazione usb, hard disk esterni) **quando non necessari** o quando si termina l'attività di lavoro, **per ridurre il rischio di accessi illeciti.**

▪ **Esegui sempre il log-out dai siti e dalle applicazioni ogni volta che smetti di usarli.**



Buone pratiche da adottare in ufficio

- **Non lasciare PC (desktop o laptop), smartphone o dispositivi di archiviazione aziendali incustoditi.**
- **Non utilizzare dispositivi e supporti che non siano espressamente autorizzati dall'organizzazione** (es. dispositivi di archiviazione usb, hard disk esterni, cloud pubblici).
- **Assicurati che tutti i dispositivi siano protetti da PIN e/o password.**
- **Ogni volta che ti allontani dal PC assicurati di bloccarlo con apposito PIN e/o password.**
- **Imposta il blocco automatico dello schermo a seguito del periodo di inattività.**
- **Non lasciare incustoditi i documenti riservati stampati quando non sono utilizzati,** è necessario che vengano archiviati in modo sicuro, chiusi a chiave.
- **Presta attenzione ai documenti lasciati incustoditi in stampanti in uso condiviso e alle scansioni effettuate su stampanti multifunzione** che indirizzano i documenti in cartelle comuni visibili a tutto il personale dell'azienda.

Buone pratiche da adottare in trasferta

- **Utilizza un privacy screen protector a protezione dei dispositivi mobili quando lavori in luoghi condivisi o sui mezzi di trasporto.**
- **Non lasciare incustodito il PC o altri dispositivi di lavoro** (es. smartphone, dispositivi di archiviazione usb o hard disk esterni autorizzati dall'organizzazione) in auto, stazioni o altri luoghi pubblici.
- **Evita di scaricare in autonomia programmi o applicazioni non autorizzati dall'organizzazione** anche se apparentemente utili e funzionali al tuo spostamento.
- **Se lo autorizza l'organizzazione, utilizza dispositivi e supporti di archiviazione removibili cifrati.**
- **Non utilizzare stazioni di ricarica usb pubbliche.**
- **Non utilizzare reti pubbliche per il collegamento a Internet senza VPN.**

Cosa accade se non si lavora in modo sicuro a casa, in ufficio o in missione?

Se sul luogo di lavoro non vengono utilizzati i cavi di sicurezza per i laptop si rischia il furto dei dispositivi non adeguatamente assicurati alla postazione.

Se durante lo smartworking non viene scelto un luogo sicuro dove lavorare si rischia di divulgare involontariamente informazioni riservate sull'organizzazione e/o sui clienti a parenti o persone estranee alla stessa che non essendo adeguatamente sensibilizzati potrebbero divulgarle in maniera involontaria.

Se non si adottano adeguate precauzioni durante il lavoro in missione si rischia non solo di incorrere nel furto dei dispositivi, lasciati ad esempio incustoditi in auto o in qualsiasi altro luogo, **ma anche di divulgare, involontariamente, informazioni riservate dell'organizzazione** e/o dei clienti a sconosciuti in ascolto delle conversazioni o che abbiano accesso visivo allo schermo del PC.

Se non si presta attenzione alla sicurezza della rete alla quale ci si collega, a casa, in ufficio e in viaggio **si permette ai cybercriminali di collegarsi ai dispositivi sfruttando le connessioni Wi-Fi non protette** e diffondere sulla rete dell'organizzazione virus e malware.

9

In caso di anomalie o situazioni sospette, contatta tempestivamente chi all'interno della tua organizzazione può aiutarti a verificare ciò che sta accadendo

AZIONI CHIAVE

1. In caso di anomalie sospette, contatta tempestivamente il personale di riferimento della tua organizzazione per assicurarti di metterlo a conoscenza dell'accaduto e farti indicare le azioni da seguire.

2. Comunica apertamente con il personale di supporto per aiutarli a capire cosa è successo e di quale assistenza hai bisogno.

3. Cambia immediatamente la password degli account compromessi se ritieni di essere stato vittima di un attacco cyber, o anche solo se lo sospetti.

4. In caso di compromissione del sistema dovuta ad esempio a malware e/o virus spegni immediatamente i dispositivi disconnettendoli dalla rete o da altri dispositivi per evitare che il malware possa continuare ad operare.

5. Fai attenzione ai segnali che possono indicarti di essere vittima di un attacco cyber: bassa velocità di elaborazione, blocchi frequenti e popup imprevisti.

CONTENUTI IN DETTAGLIO

In caso di anomalie o situazioni sospette il tempo ricopre un ruolo fondamentale, in quanto permette di attenuare le possibili conseguenze in cui l'organizzazione potrebbe incorrere a seguito di un attacco cyber. Se ritieni di essere vittima di un attacco cyber o hai la percezione che un attacco sia in corso, per evitare di subire conseguenze più gravi, **notifica immediatamente l'evento al personale competente, segui le istruzioni e le linee guida previste dall'organizzazione e non cercare di risolvere in autonomia.** L'obiettivo, qualora possibile, è quello di agire preventivamente per la tutela e salvaguardia dell'organizzazione segnalando eventuali irregolarità o eventi anomali sospetti per agevolare il personale competente a verificare e indagare sulle anomalie individuate.

È importante fare attenzione ai segnali che indicano che l'account o il PC sono stati compromessi. Gli indicatori comuni sono la bassa velocità di elaborazione, i blocchi frequenti e i programmi, i popup o le barre degli strumenti imprevisti.

In caso di anomalie o situazioni sospette, ecco alcune buone pratiche che devi seguire:

▪ **Avvisa tempestivamente il personale competente dell'organizzazione** per assicurarti che sia a conoscenza dell'incidente e per ricevere indicazioni sul piano di risposta agli incidenti da seguire; in tal caso è importante comunicare apertamente per aiutarlo a capire cosa è successo e di quale assistenza si ha bisogno.

▪ **Se sono stati compromessi i dati di altre persone** (es. clienti, fornitori), **è fondamentale notificare l'evento ai soggetti responsabili della cybersicurezza dell'organizzazione** (es. responsabile per la cybersicurezza o responsabile della protezione dei dati

personali) per gestire l'eventuale necessità di segnalazione dell'incidente alle Autorità di Controllo competenti nei tempi previsti.

▪ **In caso di infezione da malware o ransomware spegni immediatamente il PC** e contatta il personale competente dell'organizzazione.

▪ **Limita le azioni, ad eccezione di quelle necessarie a fermare la violazione della sicurezza.**

▪ **Limita i danni, non trasmettere mai copie di dati che potrebbero essere stati compromessi.**

A cosa si va incontro se non si contatta tempestivamente il personale competente per fronteggiare un reale o potenziale attacco cyber?

Se non si comunica tempestivamente al personale competente un reale o potenziale attacco cyber, **si rischia che l'attacco vada a buon fine**. Ciò può comportare, tra le altre cose, la **divulgazione di informazioni riservate**.

Se non si attuano immediatamente tutte le misure previste, volte a contenere e notificare l'incidente di sicurezza in atto, come cambiare immediatamente la password o spegnere il PC, **si rischia di diffondere maggiormente eventuali malware o virus presenti nel dispositivo**.

La diffusione della notizia di un attacco cyber riuscito nei confronti dell'organizzazione, anche a causa della negligenza del personale, **comporta una perdita di fiducia e credibilità da parte di clienti, fornitori** con conseguenti danni reputazionali ed economici per la stessa.

Lista degli acronimi

ACN	agenzia per la cybersicurezza nazionale
CEO	chief executive officer
CSIRT	computer security incident response team
IA	intelligenza artificiale
IoT	internet of things
MFA	multi factor authentication
NIS	network and information security
NIST	national institute of standards and technology
PMI	piccole e medie imprese
VPN	virtual private network